

Proposta de Segurança

Grupo D: Software House SaaS

SSI, Aula 04/05

1. Introdução

Uma Software House SaaS é uma empresa que disponibiliza sistemas pela internet. Os clientes acessam pelo navegador sem instalar nada. Por lidar com dados de muitos clientes, precisa de segurança em camadas (Defesa em Profundidade), onde múltiplos controles se sobrepõem para proteger o sistema.

2. Cenário

Software House com 80 funcionários, plataformas web multi-tenant, APIs de integração, hospedagem em nuvem e suporte técnico. Ativos críticos: dados dos clientes, código-fonte, credenciais e infraestrutura de produção.

3. Arquitetura em Camadas

3.1 Firewall

Primeiro filtro de segurança, decide quem entra e quem fica de fora. Usaremos NGFW (Firewall de Nova Geração) com DPI (Inspeção Profunda de Pacotes), regras explícitas e bloqueio de portas não utilizadas.

3.2 IDS e IPS

IDS monitora e avisa sobre atividades suspeitas. IPS bloqueia o ataque automaticamente. IPS em linha com assinaturas atualizadas semanalmente e análise heurística.

3.3 DMZ

Área de transição entre internet e rede interna. Servidores web e API ficam na DMZ, acesso restrito às portas 443 e 80, sem dados sensíveis nessa zona.

3.4 Segmentação de Rede

Rede dividida em VLANs para isolar setores:

- VLAN 10, Desenvolvimento: código e testes
- VLAN 20, Produção: servidores e banco de dados
- VLAN 30, Administrativo: RH e Financeiro
- VLAN 40, Convidados: acesso limitado

4. Proteção de Endpoint

EDR (Endpoint Detection and Response) monitora comportamento do sistema em tempo real e detecta ataques inéditos, ao contrário do antivírus tradicional que só reconhece malwares conhecidos. EDR em todos os endpoints, monitoramento 24/7, isolamento remoto e integração com SIEM.

5. Autenticação e Identidade

5.1 MFA (Autenticação Multi-Fator)

Exige pelo menos dois fatores: algo que você sabe (senha), algo que você possui (código no celular) e, para acessos privilegiados, algo que você é (biometria).

- MFA obrigatório para todos e para acesso a produção
- SSO (Single Sign-On) nos sistemas internos
- Bloqueio após 5 tentativas incorretas

5.2 Menor Privilégio

Cada pessoa só acessa o que precisa para seu trabalho. Revisão trimestral de acessos, sem admin em computadores comuns.

6. Dados e Backup

6.1 Criptografia

AES-256 em dados parados (repouso), TLS 1.3 em dados viajando (trânsito), chaves em cofre virtual (KMS) e DLP bloqueando envio de dados sensíveis.

6.2 Backup 3-2-1-1-0

3 cópias, 2 meios diferentes, 1 fora da empresa, 1 offline/imutável, 0 erros no teste. Banco de dados: diário. Código: a cada commit. Configurações: semanal. Teste de restauração: mensal.

7. Segurança de APIs

Autenticação OAuth 2.0, rate limiting por cliente/IP, validação de entrada, WAF contra SQL Injection e XSS, CORS explícito e pentest semestral.

8. Resposta a Incidentes

Detecção 24/7 com EDR/SIEM, contenção (isolamento), erradicação (remoção da ameaça), recuperação (backup imutável) e pós-incidente (análise e melhoria).

9. Orçamento

Camada	%	Valor
Firewall e Perímetro	25%	R\$ 50.000
EDR e Endpoint	20%	R\$ 40.000
MFA e Identidade	15%	R\$ 30.000
Backup e Criptografia	15%	R\$ 30.000
IDS/IPS e Monitoramento	10%	R\$ 20.000
WAF e Segurança de API	10%	R\$ 20.000
Treinamento	5%	R\$ 10.000
TOTAL	100%	R\$ 200.000

Total estimado primeiro ano: R\$ 180.000 a R\$ 250.000 (licenças, implantação, treinamento).

10. Conclusão

Segurança em Software House SaaS vai além de antivírus. Firewall, IDS/IPS, DMZ, EDR, MFA, backup imutável e monitoramento constante formam a defesa. Implementação gradual, priorizando o mais crítico, mantém confiança dos clientes e conformidade com a LGPD.

Referências

- Aula 04, Mecanismos de Segurança (ETEC)
- OWASP Top 10:2025
- NIST Cybersecurity Framework 2.0
- NIST SP 800-207, Modelo Zero Trust
- CSA, Segurança SaaS 2026